

Cybersecurity Incident Response Policy

Meridian Global Corp — Confidential Internal Document

文件编号: MSG-IRP-2024.01

版本: 1.0

生效日期: 2024年3月15日

制定部门: 信息安全部

****网络安全事件响应策略****

1. 目的与范围

****1.1 目的****

本策略旨在为梅瑞狄安寰球公司 (Meridian Global Corp.) 建立一个清晰、高效且可操作的网络安全事件响应框架，确保公司能够及时、有效、系统地响应各类网络安全事件。其核心目标在于最大程度地降低事件对业务运营、数据机密性、完整性与可用性以及公司声誉造成的影响，同时确保所有响应活动均符合适用的法律法规及行业标准。

****1.2 范围****

本策略适用于梅瑞狄安寰球公司全球范围内的所有员工、承包商、第三方服务提供商，以及公司拥有的、租用的或管理的任何信息系统、网络基础设施、软件应用和所处理的所有数据。

2. 定义

****2.1 网络安全事件 (Cybersecurity Incident)****

指对公司信息系统、网络或数据造成未经授权的访问、使用、泄露、修改或破坏，或影响其可用性、机密性、完整性的任何事件或潜在事件。

****2.2 响应时间 (Response Time)****

指从事件被检测或报告并被确认其级别之日起，到事件响应团队开始采取初步行动的时间。

****2.3 首席信息安全官 (CISO)****

指梅瑞狄安寰球公司负责公司整体信息安全策略、管理和运营的最高级别官员。目前由张华先生担任。

3. 事件响应团队 (IRT)

梅瑞狄安寰球公司建立跨部门的事件响应团队 (IRT)，负责协调和执行本策略规定的所有事件响应活动。IRT的核心成员包括：信息安全部、IT运营部、法务部、人力资源部和企业传播部。在P1关键事

件中，首席信息安全官 (CISO)
张华先生将担任总指挥，负责协调所有响应活动并向高级管理层汇报。

4. 事件分类与响应时间

根据网络安全事件对公司业务运营、数据安全和公司声誉的潜在影响程度，事件分为以下四个级别，并对应不同的响应要求：

4.1 P1 关键 (Critical)

***定义**：对公司核心业务运营、敏感数据机密性、完整性或可用性造成严重损害，或可能导致重大法律、财务或声誉风险的事件。

***示例**：大规模数据泄露、勒索软件攻击导致核心系统停摆、关键生产系统遭受未经授权的破坏、直接导致重大经济损失的欺诈行为。

***响应要求**：从事件被确认之日起，必须在 **15分钟内** 开始初步响应，并**立即**上报首席信息安全官 (CISO) 及相关高级管理层。

4.2 P2 高 (High)

***定义**：
对公司部分业务或重要数据造成显著影响，或可能引发监管关注，但尚未达到P1级别的事件。

***示例**：未经授权的系统入侵（未影响核心业务）、重要服务器或应用服务中断、大量敏感数据被访问但未被公开。

***响应要求**：从事件被确认之日起，必须在 **1小时内** 开始初步响应。

4.3 P3 中 (Medium)

***定义**：对公司非核心业务或系统造成局部影响，或潜在导致轻微数据泄露的事件。

***示例**：广泛传播的恶意软件检测（未造成系统破坏）、单个用户账户被盗用、非关键业务系统暂时性中断、网络钓鱼攻击成功但影响有限。

***响应要求**：从事件被确认之日起，必须在 **4小时内** 开始初步响应。

4.4 P4 低 (Low)

***定义**：对公司影响最小的事件，主要涉及政策违规或轻微安全漏洞。

***示例**：员工违反安全政策、发现小型僵尸网络活动（未影响内部系统）、非敏感信息的小规模泄露、非关键系统的配置错误。

***响应要求**：从事件被确认之日起，必须在 **5个工作日内** 开始初步响应。

5. 响应流程与步骤

所有网络安全事件的响应活动应遵循以下流程：

1. ****检测与报告****: 通过安全信息和事件管理系统 (SIEM)、入侵检测系统 (IDS)、防病毒软件、员工报告或第三方通知，发现并记录事件。员工应通过公司内部安全热线 (内线 8888) 或专用邮箱 (security@meridianglobal.com) 报告可疑事件。
2. ****初步响应与评估****:
确认事件真实性，评估其级别 (P1-P4)，并启动相应级别的响应流程和团队。
3. ****遏制****:

****隔离受影响系统****:
迅速将受影响的系统、网络、服务或账户从公司网络中隔离，以防止事件进一步扩散。

****保存日志与证据****: 严格按照数字取证标准，保存所有相关的日志文件、系统镜像、内存转储及其他数字证据，确保证据链的完整性。

****通知法务部门****:
对于所有P1和P2事件，或任何可能涉及法律责任的事件，立即通知公司法务部门进行评估和指导。
4. ****根除****: 清理恶意代码、删除后门、修复漏洞，确保事件源被完全消除，防止二次感染。
5. ****恢复与正常化****: 在确保安全的前提下，恢复受影响的服务和数据。对相关系统进行全面安全检查和加固，确保系统已恢复到安全状态，防止类似事件再次发生。
6. ****事后分析与总结****: 收集事件响应过程中的所有数据，进行深入分析，形成详细的事件报告。

6. 监管与合规通知

****6.1 CERT-In 通知****

对于被认定为 ****P1 关键级别**** 的网络安全事件，梅瑞狄安寰球公司将根据印度信息技术法 (Information Technology Act, 2000) 及其相关修正案的规定，在事件发现后的 ****6小时内****，向印度计算机应急响应小组 (CERT-In) 提交初步通知。

****6.2 其他监管通知****

对于涉及其他司法管辖区（如欧盟、美国、中国）的数据泄露或其他监管敏感事件，公司将严格遵循当地法律法规，在规定时间内向相关监管机构进行通知，确保全面合规。法务部门将主导此类通知的审核与提交。

7. 事后评审

****7.1 强制评审****

对于所有 ****P1 关键****和 ****P2 高级别****的网络安全事件，必须在事件解决后的 ****5个工作日内****强制进行事后评审会议。

****7.2 评审内容****

评审内容包括但不限于：事件发生原因（根本原因分析）、响应过程的有效性、采取的遏制和恢复措施、未能及时响应的因素、事件影响评估以及未来预防和改进措施。评审结果需形成正式报告并存档，以指导策略、流程和技术改进，避免同类事件再次发生。

8. 培训与意识

梅瑞狄安寰球公司将定期为全体员工提供网络安全意识培训和事件报告流程指导，确保所有员工了解本策略的重要性，并能够在发现可疑活动或潜在安全事件时及时、准确地报告。

9. 策略审查与更新

本策略将至少每年进行一次审查，以确保其持续的有效性和适用性。此外，在发生重大组织结构调整、技术变革或相关法律法规更新时，本策略也将进行修订。修订后的版本将通过公司内部渠道（如内部门户、电子邮件）向全体员工发布。